

# Manual 12 - Implementación Controlada de Privacidad de California CCPA / CPRA

---

## CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: 93d5831ff3bd2349eb4973e3a77a8bd3d301c1d4 | Idioma: es-419 | se mantienen los límites jurídicos de privacidad de California y las fechas de cumplimiento escalonadas.

**Límite jurídico y de aseguramiento:** Este manual operacionaliza prácticas de privacidad de California, pero no proporciona asesoría jurídica específica para una organización, no determina aplicabilidad o exenciones, no establece suficiencia de evaluaciones de riesgo, no decide alcance de auditorías de ciberseguridad, no determina cobertura ADMT, no establece responsabilidad ni garantiza cumplimiento de CCPA/CPRA. Las obligaciones vigentes y escalonadas deben aplicarse según sus fechas efectivas y con juicio humano jurídico/de privacidad competente.

## Rutas de implementación

### Manual 12 — Rutas de implementación CCPA / CPRA

Borrador controlado asistido por máquina (es-419). La edición en inglés sigue siendo la fuente controlada. Esta localización no constituye aprobación jurídica, semántica o terminológica humana y permanece sujeta a revisión competente antes de publicación.

Estas rutas escalan la profundidad de implementación sin modificar las obligaciones jurídicas subyacentes. La aplicabilidad y la interpretación jurídica siguen siendo específicas de cada organización y requieren juicio humano competente.

#### Ruta A — Esencial

Diseñada para organizaciones más pequeñas o menos complejas cuyas obligaciones de privacidad de California puedan operarse mediante un entorno de datos comparativamente acotado.

Paquete operativo mínimo:

- análisis de aplicabilidad y umbrales;
- inventario de roles para relaciones de empresa, proveedor de servicios, contratista y terceros;
- inventario de información personal e información personal sensible;
- controles de aviso al momento de recopilación y política de privacidad;
- ingreso, verificación, respuesta, plazos y evidencia de derechos de consumidores;
- gestión de venta/intercambio y señales de preferencia de opt-out;
- reglas de conservación/eliminación;
- controles contractuales para proveedores de servicios/contratistas;
- selección para evaluación de riesgos;
- línea base de seguridad razonable;
- registro de evidencia y revisión periódica de gestión.

#### Ruta B — Estructurada

Diseñada para organizaciones con múltiples unidades de negocio, sitios web/apps, ecosistemas publicitarios, proveedores, productos de datos o mayor volumen de solicitudes de consumidores.

Añada:

- inventario empresarial de flujos de datos y finalidades;
- pruebas automatizadas de señales de preferencia de opt-out;
- controles de uso/divulgación de información personal sensible;
- flujo de opt-in para menores cuando corresponda;
- gobierno de incentivos financieros;
- debida diligencia formal para proveedores de servicios/contratistas;
- metodología documentada de evaluación de riesgos y comité de revisión;
- planificación de preparación para auditorías de ciberseguridad;

- inventario de ADMT y selección de aplicabilidad;
- métricas de calidad de solicitudes y revisión de excepciones;
- validación de conservación/eliminación de datos;
- integración de ingeniería de privacidad en gestión de cambios;
- paquete de evidencia para respuesta regulatoria.

## Ruta C — Mejorada

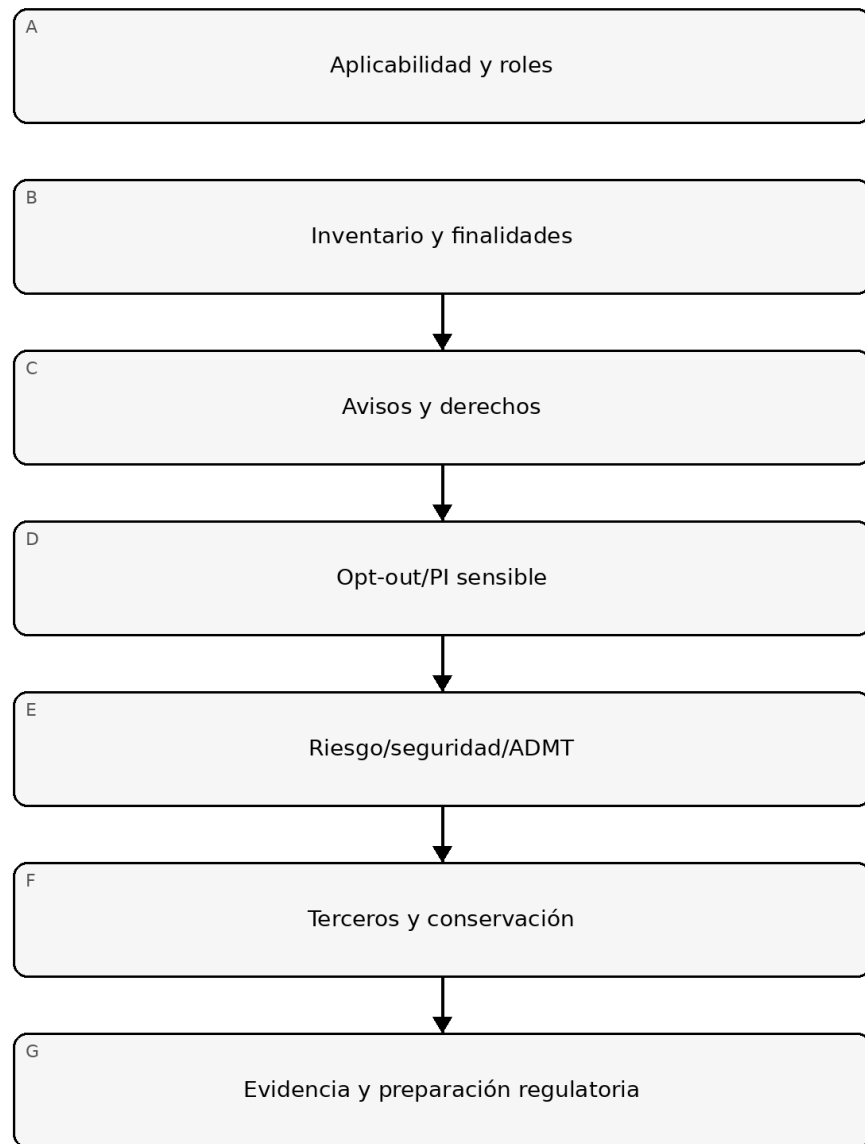
Diseñada para organizaciones grandes, intensivas en datos, con alta actividad publicitaria, habilitadas por IA, multinacionales o altamente reguladas.

Añada:

- marco empresarial de controles de privacidad de California;
- descubrimiento automatizado de datos con validación humana;
- monitoreo continuo de señales de preferencia;
- gobierno avanzado de publicidad, medición y resolución de identidad;
- controles centralizados de información personal sensible;
- gobierno formal de cartera de evaluaciones de riesgo;
- desafío independiente para evaluaciones de riesgo materiales;
- arquitectura de evidencia para auditoría de ciberseguridad y preparación para plazos escalonados;
- gobierno de decisiones significativas con ADMT, avisos previos al uso, operaciones de acceso/opt-out y preparación para 2027;
- selección de aplicabilidad para corredores de datos/DROP cuando corresponda;
- monitoreo continuo de terceros y flujos de datos;
- métricas ejecutivas de privacidad y seguimiento de acciones correctivas;
- cruces con RGPD, NIST Privacy Framework, ISO/IEC 27701, ISO/IEC 27001 y requisitos sectoriales cuando sea útil.

# Ciclo de privacidad de California de siete compuertas

**Gráfico de memoria del Manual 12 1**

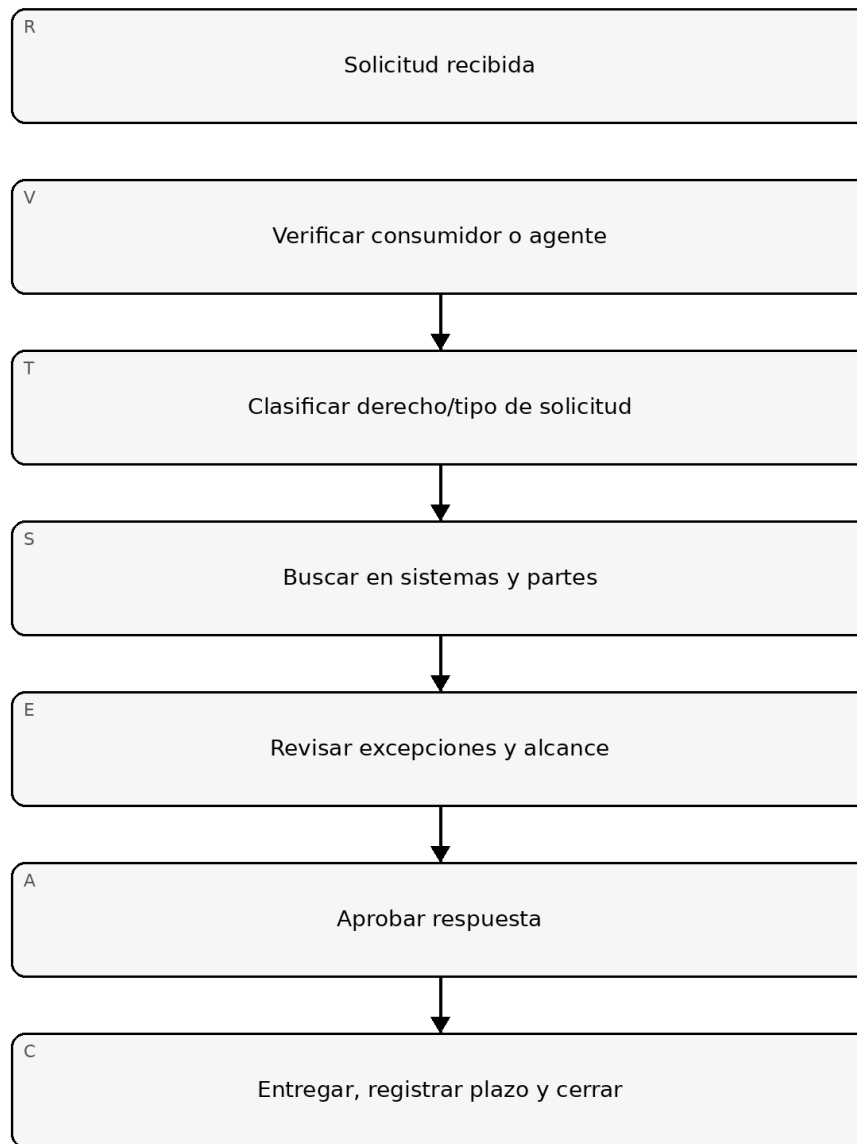


**Figura 1. Gráfico de memoria de implementación de privacidad de California**

Explicación accesible: El ciclo de privacidad de California comienza con análisis de aplicabilidad y roles, luego mapea datos y finalidades, operacionaliza avisos y derechos, gestiona opt-out e información personal sensible, evalúa obligaciones de riesgo/seguridad/ADMT, gobierna terceros y conservación y mantiene evidencia para revisión y preparación regulatoria.

## Enrutamiento de derechos de consumidores

**Gráfico de memoria del Manual 12 2**

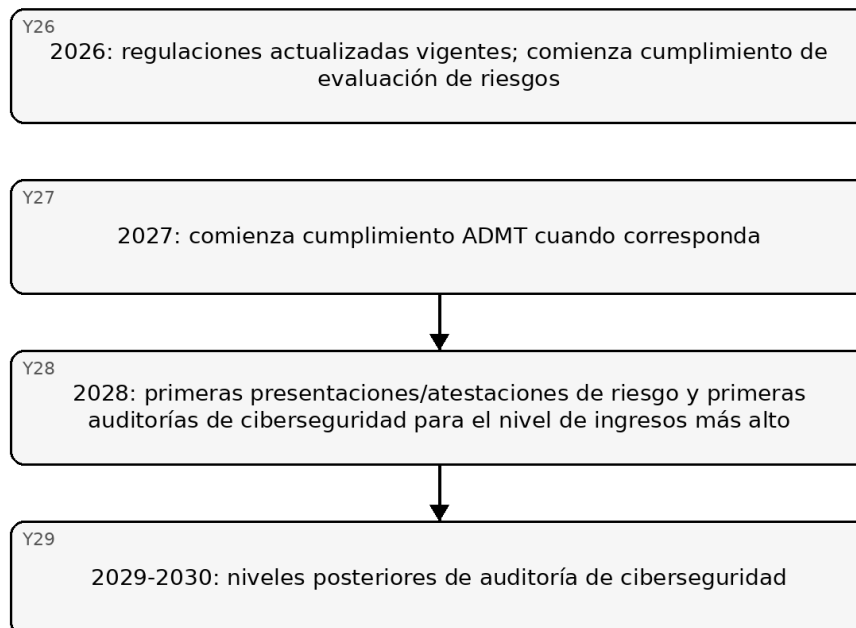


**Figura 2. Gráfico de memoria de implementación de privacidad de California**

Explicación accesible: Una solicitud debe validarse, clasificarse, buscarse en sistemas relevantes y partes posteriores, revisarse frente a excepciones o límites de alcance aplicables, aprobarse por personal responsable, entregarse dentro de los plazos aplicables y cerrarse con evidencia.

## Cronología regulatoria escalonada 2026–2028

### Gráfico de memoria del Manual 12 3



**Figura 3. Gráfico de memoria de implementación de privacidad de California**

Explicación accesible: Las regulaciones actualizadas de la CCPA están vigentes en 2026, pero algunas fechas de cumplimiento son escalonadas. Las obligaciones de evaluación de riesgos comienzan en 2026; los requisitos de ADMT comienzan en 2027 cuando sean aplicables; las presentaciones/atestaciones de evaluación de riesgos y las primeras auditorías de ciberseguridad comienzan en 2028, seguidas por niveles posteriores. La aplicabilidad y las fechas exactas deben volver a verificarse en el candidato final.

### Límite fail-closed

La automatización puede validar registros requeridos, campos de plazos, completitud de flujos de solicitudes, pruebas de señales de preferencia, enlaces de evidencia y etiquetas de estado de fuentes. No puede emitir conclusiones jurídicas finales específicas de una organización sobre aplicabilidad, exenciones, clasificación ADMT, suficiencia de evaluación de riesgos, alcance de auditoría o cumplimiento. La revisión humana competente de privacidad/jurídica sigue siendo obligatoria. La autorización final de liberación del propietario se aplica conforme al procedimiento permanente del repositorio una vez que todas las compuertas sustantivas anteriores estén en verde.

# Manual controlado de 32 capítulos

## Capítulo 01 — Propósito y responsabilidad de privacidad de California

Establezca un modelo operativo controlado que conecte los requisitos de privacidad de California con responsables definidos, inventarios de datos, sistemas, sitios web/apps, tecnologías publicitarias, proveedores, contratos, operación de derechos de consumidores, evaluaciones de riesgo, seguridad, ADMT, conservación, evidencia y revisión de gestión.

Las conclusiones de aplicabilidad deben documentarse con hechos, umbrales, exenciones consideradas, revisor, fecha, supuestos y preguntas no resueltas.

## Capítulo 02 — Aplicabilidad, umbrales y exenciones

Evalúe si una entidad cumple la definición legal vigente de empresa cubierta y si determinados tratamientos o datos se encuentran dentro de una exención o regla especial. Considere ingresos, volumen de datos, criterios de venta/intercambio, relaciones con entidades bajo control común, alcance de consumidores de California y el modelo real de tratamiento.

No infiera aplicabilidad únicamente por tamaño o ubicación de la empresa. Reevalúe después de fusiones, cambios de modelo de negocio, nuevos usos de datos, cambios publicitarios o modificaciones de umbrales.

## Capítulo 03 — Roles de empresa, proveedor de servicios, contratista y terceros

Clasifique a las partes según el uso real de datos, restricciones contractuales, finalidades, instrucciones, divulgaciones posteriores y derechos independientes, y no solo por etiquetas.

Mantenga un registro de roles que conecte cada relación con categorías de datos, finalidades, contratos, estado de venta/intercambio, restricciones de proveedor de servicios/contratista, subprocessadores o partes posteriores y activadores de revisión.

## Capítulo 04 — Información personal y contexto de hogar/dispositivo

Inventaríe información que identifique, se relacione con, describa, sea razonablemente capaz de asociarse con o pueda vincularse razonablemente con un consumidor o un hogar cuando corresponda. Incluya identificadores en línea, datos de dispositivos, comportamiento de navegación, geolocalización, información comercial, información laboral cuando esté cubierta, inferencias y registros vinculados.

Registre exclusiones o tratamiento de datos desidentificados/agregados con evidencia de respaldo y restricciones de reidentificación cuando corresponda.

## Capítulo 05 — Información personal sensible

Identifique información personal sensible y determine qué restricciones de uso/divulgación, avisos, derechos, controles de seguridad y limitaciones de finalidad se aplican. Mapee la PI sensible a sistemas, finalidades, destinatarios, acceso, conservación y partes posteriores.

El tratamiento de PI sensible de alto riesgo debe alimentar el gobierno de evaluación de riesgos, seguridad, proveedores, ADMT e incidentes.

## Capítulo 06 — Limitación de finalidad y minimización de datos

Defina finalidades específicas para recopilación, uso, conservación e intercambio. Recopile y use datos de manera proporcional a finalidades divulgadas y compatibles y realice análisis de cambio antes de ampliar materialmente el uso.

Las decisiones de minimización deben reflejarse en recopilación a nivel de campos, configuración de SDK/etiquetas, analítica, publicidad, conservación, acceso, exportaciones, conjuntos de datos de entrenamiento e instrucciones a proveedores cuando corresponda.

## Capítulo 07 — Gobierno de privacidad y derechos de decisión

Defina responsabilidades entre privacidad, jurídico, seguridad, producto, ingeniería, marketing, publicidad, datos, compras, RR. HH., soporte al cliente, respuesta a incidentes, auditoría y liderazgo ejecutivo.

Establezca escalamiento para incertidumbre de aplicabilidad, conflictos de derechos, preguntas de venta/intercambio, PI sensible, menores, incentivos financieros, evaluaciones de riesgo, auditorías de ciberseguridad, ADMT, corredores de datos y asuntos regulatorios.

## Capítulo 08 — Compuerta fail-closed de fundamentos

No proceda como si el programa de privacidad de California estuviera correctamente delimitado cuando la aplicabilidad no esté resuelta, los flujos materiales de datos sean desconocidos, las partes estén mal clasificadas, no se haya identificado PI sensible o falten responsables de negocio y revisores jurídico/de privacidad.

La automatización puede apoyar cálculos de umbrales y descubrimiento de datos, pero no puede tomar determinaciones finales de aplicabilidad, exención o rol sin revisión humana competente.

## Capítulo 09 — Aviso al momento de recopilación

Proporcione la información requerida en el momento de la recopilación o antes, en un formato adecuado para la interacción. Conecte los avisos con las categorías reales recopiladas, finalidades, PI sensible, conservación, venta/intercambio y derechos pertinentes.

El diseño del aviso debe contemplar sitios web, apps móviles, recopilación fuera de línea, dispositivos conectados, formularios, centros de llamadas, empleados/candidatos cuando estén cubiertos y otros canales de recopilación.

## Capítulo 10 — Política de privacidad y gobierno de divulgaciones

Mantenga una política de privacidad que describa con exactitud las prácticas vigentes y los derechos aplicables de los consumidores. Establezca responsables, control de versiones, revisión jurídica, accesibilidad, activadores de actualización, evidencia y sincronización con inventarios de datos y relaciones posteriores.

Cambios materiales en finalidades, venta/intercambio, PI sensible, ADMT, proveedores u operación de derechos deben activar revisión de impacto sobre la política.

## Capítulo 11 — Ingreso y verificación de solicitudes de consumidores

Proporcione los métodos requeridos para que los consumidores presenten solicitudes aplicables e implemente verificación de identidad/autoridad proporcional a la solicitud y a los datos involucrados.

Mantenga controles para agentes autorizados, solicitudes de hogar cuando corresponda, menores, contextos con y sin cuenta, solicitudes sospechosas, fallas de verificación y entrega segura de respuestas.

## Capítulo 12 — Derechos de conocer/acceder y portabilidad de datos

Implemente búsqueda, agregación de datos, análisis de categorías/información específica, identificación de fuente/finalidad/destinatario, revisión de excepciones, formato, seguridad, aprobación, plazos y entrega para solicitudes aplicables de acceso/conocimiento.

La evidencia debe mostrar qué sistemas y partes posteriores fueron revisados, limitaciones aplicadas, decisiones tomadas y cuándo se entregó la respuesta.

## Capítulo 13 — Eliminación y corrección

Enrute solicitudes de eliminación y corrección a través de sistemas pertinentes y proveedores de servicios/contratistas, aplique excepciones documentadas cuando corresponda, valide la finalización posterior y preserve evidencia sin conservar innecesariamente los datos que deben eliminarse.

Los flujos de corrección deben abordar decisiones de fuente autorizada, registros contradictorios, datos derivados y reprocesamiento hacia sistemas dependientes cuando sea requerido.

## Capítulo 14 — Venta, intercambio y señales de preferencia de opt-out

Determine si las divulgaciones constituyen venta o intercambio según las definiciones aplicables de California y opere mecanismos de opt-out en consecuencia. Implemente señales reconocidas de preferencia de opt-out de manera coherente con la regulación vigente y con el modelo de tratamiento de la organización.

Las pruebas deben cubrir sitios web, apps, plataformas de consentimiento/elección, etiquetas publicitarias, SDK, flujos del lado del servidor, resolución de identidad, partes posteriores y comportamiento después del opt-out.

## Capítulo 15 — PI sensible, menores y controles especiales de elección

Cuando corresponda, implemente el derecho a limitar determinados usos/divulgaciones de información personal sensible y los avisos o mecanismos requeridos. Para menores, implemente procesos de opt-in y consentimiento sensibles a la edad y coherentes con los requisitos aplicables.

No utilice patrones oscuros ni diseños de interfaz que deterioren materialmente la capacidad de elección del consumidor.

## Capítulo 16 — Incentivos financieros y compuerta fail-closed de derechos

Cuando incentivos financieros o diferencias de precio/servicio dependan de información personal, mantenga avisos requeridos, registros de valoración o justificación, procesos de opt-in/retiro y coherencia con los requisitos jurídicos vigentes.

No apruebe la compuerta cuando los avisos difieran materialmente de la práctica, las solicitudes no puedan cumplirse de extremo a extremo, se ignoren señales de preferencia de opt-out, falten controles de PI sensible o las elecciones de consumidores sean socavadas por el comportamiento de la interfaz.

## Capítulo 17 — Aplicabilidad e ingreso de evaluación de riesgos

Identifique actividades de tratamiento que activen los requisitos vigentes de evaluación de riesgos de California y mantenga un proceso de ingreso que capture finalidad, datos, consumidores, tecnología, beneficios, impactos negativos, salvaguardas, partes interesadas y responsables de decisión.

El cumplimiento de evaluación de riesgos forma parte de la línea base vigente de 2026 cuando corresponda. Las decisiones de selección deben documentarse y revisarse después de cambios materiales.

## Capítulo 18 — Análisis y aprobación de evaluación de riesgos

Evalúe la relación entre beneficios del tratamiento y riesgos para consumidores utilizando la metodología regulatoria vigente. Documente hechos, supuestos, impactos negativos, salvaguardas, alternativas, riesgo residual, revisores, aprobación y seguimiento requerido.

Las plantillas y puntuaciones automatizadas pueden apoyar la consistencia, pero no pueden establecer suficiencia jurídica ni sustituir revisión humana responsable.

## Capítulo 19 — Preparación para auditoría de ciberseguridad

Determine si aplican requisitos de auditoría de ciberseguridad y construya arquitectura de evidencia antes del plazo de presentación/certificación aplicable. Mantenga gobierno del alcance de auditoría, inventario de sistemas/datos, evidencia del programa de seguridad, independencia del evaluador, hallazgos, remediación y certificación ejecutiva cuando sea requerida.

Las regulaciones están vigentes en 2026, mientras las primeras fechas de presentación están escalonadas a partir de 2028. La preparación no debe confundirse con afirmar que una presentación de 2026 ya es exigible.

## Capítulo 20 — Seguridad razonable y evidencia de incidentes

Implemente seguridad razonable adecuada a la naturaleza de la información personal y al riesgo organizacional. Conecte control de acceso, gestión de vulnerabilidades, configuración, cifrado o salvaguardas equivalentes, monitoreo, respuesta a incidentes, resiliencia, pruebas, seguridad de proveedores y remediación con evidencia.

Cuando el derecho privado de acción legal pueda aplicar a incidentes de seguridad que cumplan los criterios pertinentes, preserve hechos y evidencia para revisión jurídica competente sin emitir conclusiones automatizadas de responsabilidad.



## Capítulo 21 — Inventario ADMT y selección de decisiones significativas

Inventaríe tecnologías de toma automatizada de decisiones e identifique finalidades, entradas, salidas, consumidores afectados, intervención humana, decisiones influenciadas, proveedores, modelos, fuentes de datos, riesgos e historial de cambios.

Determine si un uso cae dentro de las reglas ADMT aplicables y conceptos de decisión significativa mediante revisión controlada jurídica/de privacidad. No suponga que todo algoritmo está cubierto ni que todo diseño con una persona en el circuito está exento.

## Capítulo 22 — Aviso previo al uso de ADMT, acceso y preparación de opt-out

Cuando corresponda, diseñe avisos previos al uso, información de acceso para consumidores, procesos de opt-out, gestión de excepciones, aplicación posterior, pruebas, evidencia y gestión de cambios para ADMT.

El cumplimiento de ADMT comienza el 1 de enero de 2027 cuando corresponda. Manual 12 debe enseñar preparación durante 2026 sin presentar obligaciones futuras como si ya fueran exigibles.

## Capítulo 23 — Proveedores de servicios, contratistas y terceros

Gobierne relaciones posteriores mediante clasificación de roles, restricciones contractuales requeridas, limitaciones de finalidad/uso, seguridad, asistencia con derechos de consumidores, propagación de eliminación/corrección, derechos de auditoría/pruebas cuando corresponda, controles de venta/intercambio, subcontratación, conservación y revisión de cambios materiales.

Las etiquetas contractuales deben corresponder al comportamiento operativo real y al uso de datos.

## Capítulo 24 — Compuerta fail-closed de riesgo/seguridad/ADMT

No apruebe la compuerta cuando falten evaluaciones de riesgo requeridas o carezcan de sustento, se ignore la aplicabilidad de auditorías de ciberseguridad, debilidades materiales de seguridad no tengan responsable, usos de ADMT no estén inventariados o fechas futuras de cumplimiento se representen de forma inexacta.

La automatización puede apoyar inventario, recopilación de evidencia, pruebas y plazos; no puede tomar conclusiones jurídicas finales sobre suficiencia de evaluación de riesgos, aplicabilidad de auditoría, cobertura ADMT o responsabilidad.

## Capítulo 25 — Operaciones de conservación, eliminación y calidad de datos

Defina conservación por finalidad, categoría, sistema, parte posterior, necesidad jurídica/de negocio y requisito de evidencia. Implemente procesos de eliminación, archivo, excepciones/conservación legal, respaldos, datos derivados y validación alineados con finalidades divulgadas y requisitos de minimización.

Los períodos de conservación deben poder explicarse y revisarse periódicamente en lugar de convertirse por defecto en almacenamiento indefinido.

## Capítulo 26 — Ecosistemas de publicidad, medición e identidad

Mapee píxeles, SDK, cookies, eventos del lado del servidor, clean rooms, servicios de resolución de identidad, proveedores de medición, socios de datos y plataformas publicitarias a categorías de datos, finalidades, análisis de venta/intercambio, contratos, comportamiento de opt-out, gestión de PI sensible y conservación.

Las pruebas técnicas deben verificar el comportamiento real de red y del lado del servidor después de las elecciones del consumidor.

## Capítulo 27 — Distinciones de corredores de datos y DROP

Determine por separado si aplican requisitos de registro de corredores de datos o obligaciones de Delete Act/DROP. Mantenga procesos de registro, divulgación, solicitudes de eliminación, correspondencia de identidad, eliminación posterior, excepciones, evidencia y preparación para auditoría cuando corresponda.

No aplique obligaciones de corredores de datos/DROP mecánicamente a todas las empresas y no las omita cuando exista una operación cubierta de corredor de datos.

## Capítulo 28 — Registros y evidencia

Mantenga evidencia de decisión y operación para aplicabilidad, avisos, solicitudes de consumidores, verificación, señales de preferencia de opt-out, PI sensible, contratos, evaluaciones de riesgo, preparación para auditoría de ciberseguridad, ADMT, conservación, corredores de datos, incidentes, capacitación, pruebas y acciones correctivas.

La evidencia debe ser atribuible, actual, limitada al tratamiento real y protegida frente a alteraciones inapropiadas.

## Capítulo 29 — Capacitación y competencia operativa

Proporcione capacitación basada en roles para privacidad, jurídico, marketing, publicidad, producto, ingeniería, seguridad, compras, soporte al cliente, RR. HH., analítica/datos, auditoría y liderazgo. La capacitación debe incluir escenarios realistas específicos de California y errores comunes de implementación.

Controle finalización, defectos recurrentes, lecciones de solicitudes de consumidores e incidentes y cambios de comportamiento cuando sean medibles.

## Capítulo 30 — Preparación para cumplimiento y respuesta regulatoria

Mantenga un paquete organizado de evidencia y un proceso de escalamiento para consultas, auditorías, investigaciones, quejas o acciones de cumplimiento de la CPPA o del Fiscal General. Preserve hechos relevantes, decisiones, comunicaciones, evidencia técnica, contratos, evaluaciones de riesgo, registros de seguridad y remediación.

Las respuestas regulatorias requieren revisión coordinada y competente jurídico/de privacidad y representaciones exactas de la práctica actual e histórica.

## Capítulo 31 — Aseguramiento, métricas y acción correctiva

Evalúe si los controles de privacidad de California están diseñados adecuadamente, implementados, operando, evidenciados y mejorados. Medidas útiles incluyen puntualidad/calidad de solicitudes, fallas de señales de opt-out, avisos desactualizados, flujos de datos sin revisar, acciones de evaluación de riesgos no resueltas, fallas de conservación, defectos de terceros, brechas en inventario ADMT y problemas recurrentes de seguridad.

QA del repositorio y pruebas internas no certifican cumplimiento ni predicen resultados regulatorios.

## Capítulo 32 — Límite de liberación del manual y mejora continua

Manual 12 solo se cierra cuando la verificación de fuentes, el maestro inglés controlado de 32 capítulos, la revisión editorial de privacidad/jurídica/técnica, la localización es-419 y pt-BR con revisión semántica humana, la revisión de gráficos/accesibilidad, QA de publicación DOCX/PDF, revisión de seguridad del repositorio/workflows, manifiesto/checksums/procedencia y reconciliación de alcance modificado en el head exacto estén completos para el mismo candidato exacto. La autorización final de liberación se aplica conforme al procedimiento permanente del repositorio una vez que todas las compuertas sustantivas anteriores estén en verde.

La finalización establece una línea base revisada de implementación y capacitación. No proporciona asesoría jurídica específica para una organización, no garantiza cumplimiento de CCPA, no determina responsabilidad ni sustituye a profesionales competentes jurídico/de privacidad o a reguladores.